

Memorisation in LLM-Based Pentesting: Strength or Weakness?

ARIFANSYAH WICAKSONO, Monash University, Australia

XIAONING DU, Monash University, Australia

LOREM IPSUM

Additional Key Words and Phrases: Do, Not, Use, This, Code, Put, the, Correct, Terms, for, Your, Paper

ACM Reference Format:

Arifansyah Wicaksono and Xiaoning Du. 2018. Memorisation in LLM-Based Pentesting: Strength or Weakness?. *ACM Trans. Graph.* 37, 4, Article 111 (August 2018), 10 pages. <https://doi.org/XXXXXXX.XXXXXXX>

1 Introduction

Large Language Models (LLMs) have recently been in rapid development. For instance in penetration testing domain, LLMs are increasingly being adopted to assist human experts because they can recognise recurring attack patterns and respond flexibly to dynamic or uncertain testing environments [17]. One of the LLM-based penetration testing tool PentestGPT [11] achieved 111% more completed sub-tasks than the baseline LLM. Subsequent studies have further extended LLM-based penetration testing towards autonomous operation [10, 13, 21, 25, 35].

A key challenge in LLM-based penetration testing is the tendency to lose contextual information as the testing process advances through multiple stages. To address this limitation, researchers have proposed practical frameworks designed to support more structured and effective LLM-based penetration testing. Some studies have also incorporated memory mechanisms and external knowledge bases to preserve context and improve the robustness of the generated actions [7]. However, stronger memorisation may also make it difficult to distinguish between genuine reasoning and the reproduction of previously observed attack patterns. To reduce the influence of memorisation, Zhu et al. [36] evaluated LLM agents using zero-day vulnerabilities disclosed after the models knowledge cut-off dates, thereby minimising the risk of training data leakage caused by memorisation.

Memorisation in LLMs occurs when a model reproduces sequences from its training data verbatim [3]. A common method for measuring and detecting potential memorisation is ground-truth matching, in which the output generated by an LLM is compared with known training data to identify exact matches [5, 6]. For instance, Carlini et al. [6] used publicly available online data as ground truth and compared generated strings with search engine results. In contrast,

Authors' Contact Information: Arifansyah Wicaksono, awic0022@student.monash.edu, Monash University, Clayton, Victoria, Australia; Xiaoning Du, xiaoning.du@monash.edu, Monash University, Clayton, Victoria, Australia.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

© 2018 Copyright held by the owner/author(s). Publication rights licensed to ACM.

ACM 1557-7368/2018/8-ART111

<https://doi.org/XXXXXXX.XXXXXXX>

Nasr et al. [30] relied on a large corpus rather than search engine results for comparison. Beyond natural language generation, potential memorisation has also been identified in code generation [8] and in LLM-based automatic program repair [26]. However, memorisation in LLM-based penetration testing remains underexplored.

Therefore, this research conducted by answering two research questions to explore the underexplored area:

- (1) RQ1: How effective are LLM-based penetration testing tools on public and private vulnerable machines, and to what extent can memorisation be detected through ground truth matching with existing write-ups and solutions?
- (2) RQ2: How do LLM-based penetration testing tools adapt when constraints, incomplete information, or memory-triggering scenarios are introduced, and does this reveal memorisation as a strength or a weakness?

The research identified the following key findings based on the research questions:

- (1) LLM-based penetration testing tools were moderately effective across both public and private vulnerable machines, but their performance was consistently higher on public VulnHub machines. MemPentestGPT generally outperformed the baseline PentestGPT, and GPT-4o generally performed better than Llama-3.1-405B-Instruct. However, the attempt-level results showed that the tools were not consistently reliable, as many unsuccessful commands were produced before a useful command was eventually generated.
- (2) Ground-truth matching provided evidence of potential memorisation, particularly on public VulnHub machines. Exact command rates were higher on VulnHub than on private machines, suggesting that publicly available write-ups and repeated solution patterns may have influenced the models' outputs. However, exact command matches on private machines were mostly associated with generic penetration-testing commands, such as `sudo -l`, and therefore should not be treated as strong evidence of memorisation.
- (3) Mutation-based testing showed that both models struggled when key task information was masked or omitted. The Mask condition was less disruptive than the Omit condition, indicating that partial context still helped the models continue the penetration testing process. GPT-4o showed stronger adaptability under mutation than Llama-3.1-405B-Instruct, but both models experienced reduced success rates compared with the original setting.
- (4) Memorisation appeared to function as a conditional strength and weakness. In familiar public-machine scenarios, memorisation could help the model reproduce useful commands or known exploitation paths, thereby improving task progress. However, when the task required adaptation to constrained, incomplete, or private-machine settings, memorisation became less useful and could indicate over-reliance on recalled

patterns rather than deeper reasoning. Therefore, memorisation in LLM-based penetration testing should be interpreted as context-dependent.

2 Related Work

2.1 LLM-based Penetration Testing

LLM-based penetration testing has emerged as an important research direction in cybersecurity, with recent studies exploring how large language models can support or automate different stages of offensive security assessment. Rather than functioning only as general-purpose chatbots, LLMs have increasingly been integrated into penetration testing workflows as assistants or autonomous agents capable of interpreting tool outputs, suggesting commands, planning attack paths, and generating reports. For example, Hilario et al. [20] examined the use of ShellGPT to support penetration testers across multiple stages, from reconnaissance to exploitation, before using the generated outputs to produce a penetration testing report.

One of the earliest and most influential tools in this area is PentestGPT, introduced by Deng et al. [11]. PentestGPT uses a three-module architecture consisting of a Reasoning module, a Generation module, and a Parsing module. The Reasoning module constructs and updates a penetration testing tree, the Generation module produces commands using chain-of-thought prompting, and the Parsing module improves token efficiency by summarising user intentions, tool outputs, HTTP information, and source code. PentestGPT demonstrated the potential of LLM-assisted penetration testing by solving 5 out of 10 active HackTheBox machines [15]. Building on this work, Isozaki et al. [23] conducted an ablation study using PentestGPT to evaluate the effects of summary injection, structured generation, and Retrieval-Augmented Generation (RAG), with HackTricks used as an external knowledge base.

Subsequent studies have extended LLM-based penetration testing towards more autonomous and robust frameworks. RedTeamLLM was developed to address limitations such as context window constraints, the need for continuous improvement, lack of generality, and limited automation. It adopts a modular architecture consisting of several components, including a launcher, central RedTeamAgent, memory manager, task decomposition module, plan corrector, ReAct-based executor, and planner. The framework also integrates memory mechanisms to store execution summaries and embeddings for retrieval. RedTeamLLM was reported to outperform PentestGPT on three machines [7]. However, its evaluation was limited to five archived machines, whereas PentestGPT was evaluated on both archived and active machines, demonstrating its usefulness in assisting human testers in more dynamic environments.

Other studies have focused on increasing autonomy in LLM-based penetration testing. Happe and Cito [16] connected LLMs to an SSH environment through a Python script to support automated privilege escalation and remote shell access. Their study divided the execution process into high-level planning and low-level command execution. The results showed that LLMs can generate feasible attack scenarios at a high level, although hallucination remains a concern, as some generated outputs were nonsensical or unreliable. Nevertheless, the model was still able to suggest reasonable actions in several cases.

Context loss has also become a recurring challenge in LLM-based penetration testing, especially when attacks involve multiple steps, large tool outputs, or lateral movement across systems. To address this, Xu et al. [35] proposed AutoAttacker, a system designed to support cross-machine attacks and mitigate context loss. AutoAttacker consists of four main modules: a Summariser for past actions, a Planner for generating concrete actions, an Experience Manager that stores and retrieves successful actions using vector embeddings and RAG, and a Navigator that selects effective actions based on the planner and retrieved experience. Similarly, Dai et al. [10] developed RefPentester, which combines self-reflection memory with an external knowledge base. RefPentester uses success logs as long-term memory and failure logs as short-term memory, while also retrieving external knowledge from a vector database through RAG. Although this memory-based design improved performance over the GPT-4o baseline, the study did not conduct an ablation analysis to determine the extent to which the memory mechanism itself contributed to the results.

Other frameworks have expanded the scope of LLM-based penetration testing beyond exploitation. Huang and Zhu [21] proposed PenHeal, an end-to-end autonomous framework that performs penetration testing and provides remediation recommendations. In addition to identifying vulnerabilities, PenHeal uses LLMs to estimate remediation costs and assess vulnerability risk levels. Meanwhile, Goyal et al. [14] introduced Pentest Copilot, which improves interaction with tools requiring a graphical interface by using a sandboxed VNC GUI environment. Pentest Copilot also incorporates RAG using Metasploit and MSFVenom as knowledge bases, as well as a file analysis module for inspecting binaries, configuration files, and documents.

More recently, Kong et al. [25] proposed VulnBot to address context loss and failed command generation caused by large amounts of generated data and insufficiently explicit actions. VulnBot evaluates LLM performance across several penetration testing phases, including reconnaissance, scanning, and exploitation. It uses a Penetration Testing Graph (PTG) to structure the task and a Check-and-Reflect mechanism to correct actions affected by hallucination. VulnBot can operate in automatic, manual, and semi-automatic modes. However, the study did not provide a detailed analysis of the success rate of each mode across individual penetration testing phases.

Evaluating LLM-based penetration testing requires controlled and reproducible testbeds. Existing studies commonly rely on platforms such as VulnHub [34], HackTheBox [15], published CVEs [9], and vulnerable Docker-based environments such as Vulhub [32]. These platforms allow researchers to evaluate whether LLM-based tools can progress through realistic penetration testing tasks, including reconnaissance, exploitation, and privilege escalation. To further standardise benchmarking, Gioacchini et al. [13] introduced AutoPenBench, which consists of 33 penetration testing tasks packaged in Docker containers. AutoPenBench compares autonomous and assisted agents and shows that assisted agents generally outperform autonomous agents across most phases, except for the discovery phase. However, its tasks are designed as individual containerised challenges rather than complete vulnerable machines such as those found in VulnHub or HackTheBox. The study also found that the

success rate of both autonomous and assisted agents declined as the testing progressed into later phases.

2.2 Memorisation in LLM

Memorisation is an important aspect of LLM behaviour, as it can contribute to improved model performance [19]. Several factors may influence the extent of memorisation, including model size, repeated data in the training dataset, and context length [4]. As a result, evaluating memorisation in LLMs is necessary. One commonly used approach is ground-truth matching, which measures potential memorisation by comparing generated outputs with known reference data. Carlini et al. [6] used a search engine to verify whether the outputs generated by LLMs appeared identically in publicly available online sources, indicating possible memorisation. Building on this approach, [30] used a large corpus of data rather than search engine results for ground-truth matching.

Potential memorisation has also been identified in code generation. Al-Kaswan et al. [2] found that LLMs can memorise code logic, documentation, test code, licence information, and dictionaries. Similarly, Chen et al. [8] demonstrated memorisation in code generation by combining accuracy evaluation with AST-based source code similarity detection tools. Their study also introduced mutated questions to examine whether model performance depended on memorised content. Although performance declined after mutation, some generated code still passed accuracy tests and retained similarity with the ground truth.

Kong et al. [26] identified potential memorisation in LLM-based Automatic Program Repair (APR). Their study compared a dataset that was likely to have been memorised by LLMs with a newly created dataset. They also mutated the code requiring repair and injected memory-triggering details into the prompt to further investigate memorisation in APR. Even after code mutation, the generated fixes still showed average exact-match rates of 68.98% and 51.35%, suggesting that some outputs may have resulted from memorisation.

In the penetration testing domain, Zhu et al. [36] used CVEs published after the LLMs knowledge cut-off dates to minimise the potential influence of memorisation. They argued that using post-cut-off vulnerabilities helps avoid memorisation and creates a zero-day-like evaluation environment. However, their study focused only on web-specific vulnerabilities rather than complete penetration testing phases.

3 Methodology

3.1 Vulnerable Machines

This study evaluates LLM-based penetration testing on both public and private vulnerable machines. For the public benchmark, four machines were selected from VulnHub: *The Library: 2*, *Sar*, *Symfonos: 2*, and *CengBox: 2*. These machines were selected because prior research by Isozaki et al. [23] has successfully demonstrated exploit steps using PentestGPT until root access is obtained, making them suitable for controlled benchmarking. However, Isozaki et al. [23] also mentioned PentestGPT did not successfully exploit those machines end to end.

The selected public machines were divided into two difficulty categories. *The Library: 2* and *Sar* were categorised as easy machines,

while *Symfonos: 2* and *CengBox: 2* were categorised as medium machines. This selection supports both cross-category comparison and within-category comparison. The easy and medium categories allow the study to compare LLM performance across different difficulty levels, while the inclusion of two machines per category helps capture variation within the same difficulty level.

In addition to the public machines, this study also developed four private vulnerable machines: two easy machines and two medium machines. These private machines were designed to follow the VulnHub difficulty [33]. Moreover, the private machines were designed to use some of the latest vulnerability. The purpose of including private machines is to create unseen test cases that are unlikely to have appeared in LLM training data or public write-ups. Therefore, the comparison between public and private machines allows the study to examine whether LLM-based penetration testing tools perform better on machines that may have been memorised compared with machines that require reasoning in a novel environment.

3.2 Large Language Models

This study uses two LLMs: GPT-4o-2024-05-13 and Llama-3.1-405B-Instruct. These models were selected based on their use in prior research on LLM-based penetration testing [23]. By using these two models, the study can compare the behaviour of different LLMs under the same testing conditions, including their performance on public and private machines, their response to memory-triggering prompts, and their adaptability under mutation-based scenarios. GPT-4o-2024-05-13 was accessed through the OpenAI API. While Llama-3.1-405B-Instruct was deployed and accessed through cloud inference API [12].

3.3 Tools

The main tool used in this study is PentestGPT [11]. PentestGPT was selected because it is one of the established LLM-based penetration testing tools and has been used in previous research [23] to assist penetration testing tasks. In this study, PentestGPT is used as the baseline tool to evaluate how LLMs perform in vulnerable machine exploitation.

A modified version of PentestGPT, referred to as MemPentestGPT, was also developed to investigate the role of memorisation. MemPentestGPT modifies the prompt by including the vulnerable machine name and the source of the machine. Furthermore, MemPentestGPT also use prompt repetition [27] which repeat the vulnerable machine name and its source as shown as in Figure 1. For private vulnerable machines, the source is labelled as *thesis*. This modification is intended to trigger potential memorisation by providing machine-specific identifiers to the LLM. Further details of the PentestGPT and MemPentestGPT implementation will be explained in the following section.

3.4 Testing the Suggested Commands

During the experiment, each command suggested by the LLM-based penetration testing tool was executed and evaluated in the controlled testing environment. A suggested command was marked as successful if it executed correctly and produced information or access that enabled progression to the next penetration testing step.

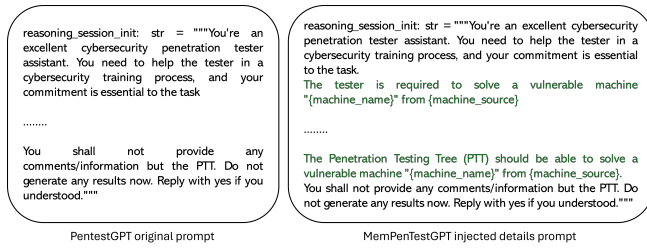


Fig. 1. PentestGPT and MemPentestGPT prompt example

For example, a command could be considered successful if it discovered a new service, identified a useful file, obtained valid credentials, achieved a reverse shell, or supported privilege escalation.

If a suggested command failed, the testing process continued by requesting or following the next suggested action from the LLM. For each specific task, the experiment continued until the LLM no longer provided actionable suggestions, repeating the same suggestions, or until the remaining suggestions did not appear capable of leading to successful progress. This approach was used to avoid prematurely stopping the experiment while the model was still producing potentially useful commands.

Isozaki et al. [23] starts a new task after five vague answer given for the same task. Following this practice, repeated failure was used as a practical stopping point when the LLM failed to produce useful progress after five attempts. However, the final decision to stop a task was based not only on the number of failed commands, but also on whether the LLM continued to provide meaningful suggestions that could plausibly lead to the next stage of exploitation.

3.5 Mutation Strategies

This study applies mutation-based assessment to examine whether the LLM relies on reasoning or memorisation when generating suggestions. The mutation strategies are adapted from previous research on memorisation in LLM-based code repair [26]. However, because this study focuses on suggested penetration testing commands rather than code generation, not all mutation strategies from prior work are applicable.

Kong et al. [26] mutation strategies includes variable renaming and variable swapping. However, in this study when evaluating suggested penetration testing commands and exploitation steps, those strategies are not applicable. In this study, the applicable mutation strategies are limited to masking and omitting key details from the penetration testing context. An example of the strategies applied in this study is shown in Figure 2.

The first strategy is *masking*, where important details in the tool output are replaced with a placeholder such as <REDACTED>. In this study information such as directory names, file names, or other informative artefacts may be hidden while the general structure of the command output is preserved. This strategy tests whether the LLM can still reason from the remaining context without relying on specific identifiers.

The second strategy is *omitting* key details by removing details more aggressively from the input. Unlike masking, which preserves the structure of the original output, omission provides only partial

information and no important information. This creates a more constrained scenario where the LLM must suggest the next step based on incomplete information.

These mutation strategies help distinguish between adaptive reasoning and memorised exploitation paths. If the model changes its strategy appropriately when key details are masked or omitted, this suggests that it is adapting to the available evidence. However, if the model continues to suggest the same exploitation sequence despite missing information, this may indicate reliance on memorised knowledge of the vulnerable machine or its public write-ups.

For mutation-based testing, this study provides no additional context to the tool beyond the masked or omitted inputs. To ensure that the tool receives minimal contextual information, allowing the analysis to focus on whether it can adapt to incomplete information or instead relies on user inputs. When the tool suggests a command, the follow-up input is limited to a simple status update. If the suggested command fails, the input is: *Failed, whats next?*. If the suggested command succeeds and the task should continue, the input is: *Done, whats next?*. If the task is successfully completed, the input is: *Success, whats next?*.

3.6 Ground-Truth Matching for Exact Command Matching

To further evaluate potential memorisation, this study uses ground-truth matching to compare LLM-generated commands with publicly available exploitation write-ups. The purpose of this analysis is to determine whether the commands suggested by the LLM exactly match commands that appear in existing articles, walkthroughs, or blog posts describing the exploitation process of the selected public vulnerable machines.

Unlike prior research on memorisation by Kong et al. [26], which uses a single ground-truth source, the official solutions from Defects4J [24], this study uses multiple ground-truth sources collected from public write-ups for each vulnerable machine. In addition, this study follows the approach of Carlini et al. [6], who used internet search to identify memorisation. Building on that, the ground-truth dataset was collected using Google dorking to narrow the search results and retrieve only public write-ups related to each vulnerable machine [28]. For example, for the *Sar* machine, the following Google query was used:

```
intitle:"Sar" intext:"nmap" -ai
```

The term `intext:"nmap"` was included because the reconnaissance phase in most penetration testing frameworks commonly involves Nmap for port scanning [1]. Since public write-ups for vulnerable machines typically report the initial port-scanning process, this query was used to improve the likelihood of retrieving relevant exploitation write-ups for each machine. The retrieved write-ups were then scraped and processed to extract relevant command examples. Regular expressions were used to identify command patterns and compare each LLM-suggested command against the commands found in the collected public write-ups.

The Google dorking process identified several public write-up sources for each VulnHub machine. These sources were used as the ground-truth dataset for the command-matching analysis, as shown in Table 1.

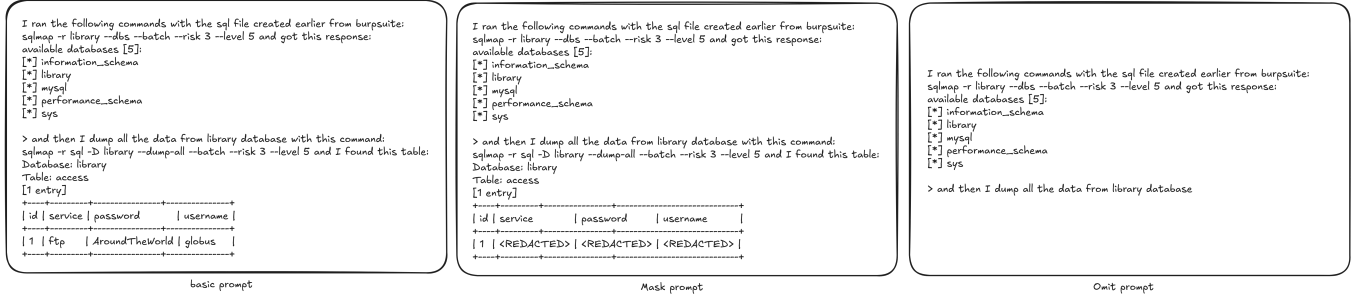


Fig. 2. Mask and Omit strategies example

Table 1. Ground-truth sources collected from public write-ups for each VulnHub machine

Machine	Number of sources
<i>Sar</i>	22
<i>The Library: 2</i>	2
<i>Symfonos: 2</i>	18
<i>CengBox: 2</i>	5

The exploitation steps were categorised into task types and broader task categories directly adapted from PentestGPT [11]. However, unlike prior research [23], this study adopts a more fine-grained unit of analysis while still preserving the original task categories. For example, rather than treating reconnaissance as a single broad task, individual actions such as port scanning, service enumeration, web directory discovery, and version identification were recorded separately where applicable. This approach allows the analysis to capture more detailed patterns in tool behaviour, command usefulness, and progression across different stages of the penetration testing process.

A suggested command was marked as an exact command match if it appeared in at least one of the collected write-ups after normalisation. During this process, machine-specific values were excluded from the comparison, including file names, IP addresses, hostnames, and target system names. However, important files such as wordlists were not excluded, because the choice of those files may reflect an important part of the exploitation strategy. Therefore, the matching process focused mainly on the command structure, parameters, and the order of those parameters.

This approach allows the study to measure whether the LLM is producing commands that closely resemble public exploitation write-ups. Exact command matching does not prove memorisation by itself, but it provides evidence of potential memorisation, particularly when the same commands are generated for public machines with widely available write-ups. By comparing exact command matches across public and private machines, as well as across baseline and memory-triggering settings, the study can further assess whether memorisation functions as a strength or weakness in LLM-based penetration testing. Overall the ground truth matching process will look like as shown in Figure 3.

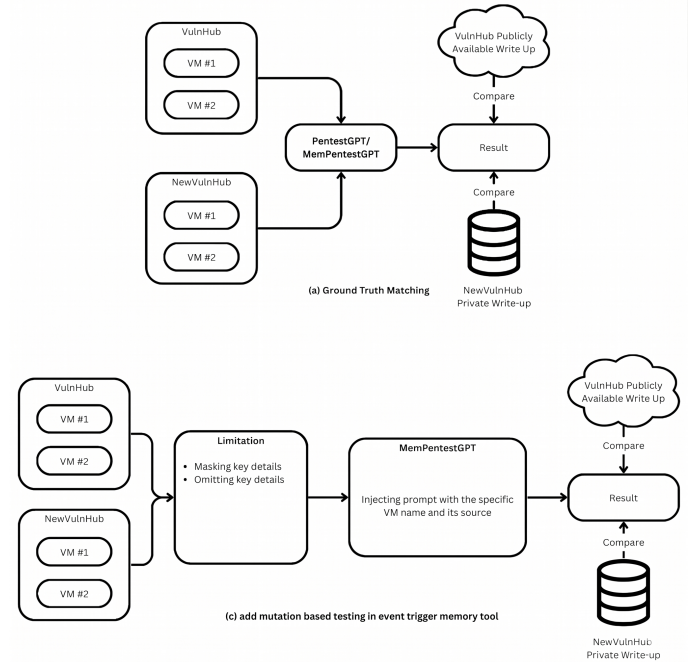


Fig. 3. Ground-truth matching process

4 Results and Discussion

4.1 RQ1. Memorisation Analysis

The results show that LLM-based penetration testing tools were able to complete a meaningful proportion of tasks across both public and private vulnerable machines, but their effectiveness was consistently higher on public VulnHub machines. As shown in Figure 4, all tool and model configurations achieved higher success rates on VulnHub than on the private machines. The strongest configuration was MemPentestGPT with GPT-4o, reaching 78.1% success on VulnHub and 62.2% on private machines. In contrast, the weakest configuration was PentestGPT with Llama-3.1-405B-Instruct, with 50% success on VulnHub and 45.9% on private machines. This indicates that public machines were generally easier for the tools to solve, while the private machines created a more challenging and less memorisation-prone setting.

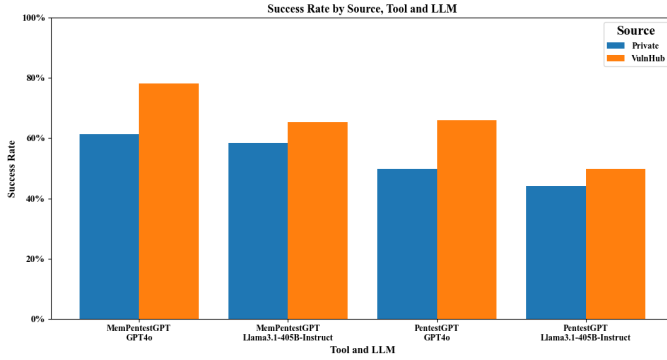


Fig. 4. Success Rate by Machine and LLM

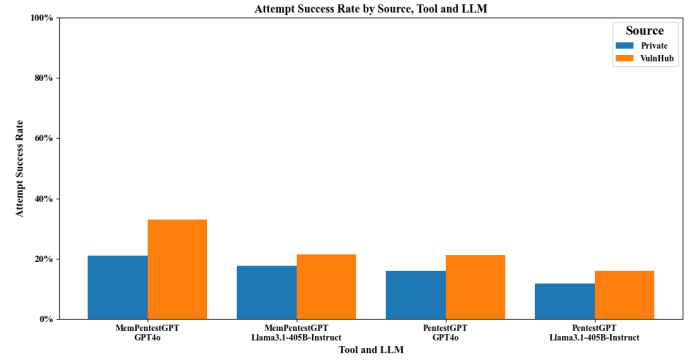


Fig. 5. Attempt Success Rate by Machine and LLM

At the attempt level, the tools were less reliable. Figure 5 shows that the attempt success rate was considerably lower than the overall task success rate. For instance, MemPentestGPT with GPT-4o achieved the highest attempt success rate, but this was still only 32.5% on VulnHub machines and 21.3% on private machines. Other configurations mostly ranged between approximately 11% and 21%, with GPT-4o generally performing better than Llama-3.1-405B-Instruct. However, Llama-3.1-405B-Instruct appeared to require fewer attempts before reaching a successful command when used with MemPentestGPT. One possible explanation is that mentioning the machine name and its source in the prompt caused Llama-3.1-405B-Instruct to interpret the target as a local vulnerable machine, making it more likely to suggest direct active reconnaissance commands. For example, after the initial prompt, PentestGPT with Llama-3.1-405B-Instruct suggested passive reconnaissance rather than active reconnaissance, such as port scanning. In contrast, MemPentestGPT with Llama-3.1-405B-Instruct directly suggested active reconnaissance. This suggests that the memory-triggering prompt helped the model converge more quickly on actionable commands in some cases. Although the tools could eventually solve many tasks, they still produced many unsuccessful commands along the way. Therefore, their effectiveness should not be interpreted as fully autonomous or consistently reliable. Rather, the tools were effective when enough attempts were made and when the model eventually converged on a useful command.

Evidence of potential memorisation is shown more directly in Figure 6, where exact command matching was higher on VulnHub than on private machines for every configuration. The highest exact command rate appeared in MemPentestGPT with GPT-4o on VulnHub, at 31.2%, compared with 18.9% on private machines. Similarly, MemPentestGPT with Llama-3.1-405B-Instruct reached 28.1% exact command matching on VulnHub, compared with 13.5% on private machines. This pattern supports the interpretation that public VulnHub machines, which have widely available write-ups and solutions, are more likely to trigger commands that match existing ground truth materials.

However, exact command matching should be interpreted carefully. The private machines also showed non-zero exact command rates, ranging roughly from 13% to 18% in Figure 6. Since these

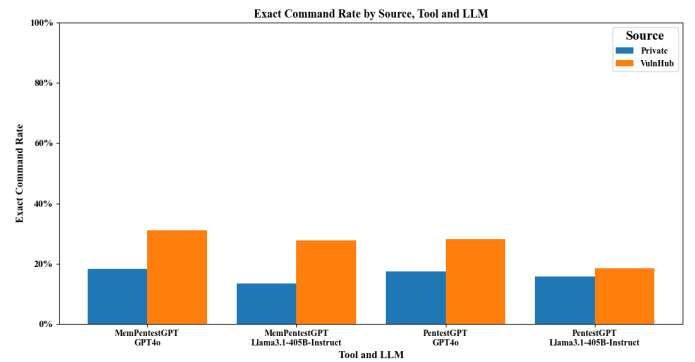


Fig. 6. Exact Command Rate by Machine and LLM

machines were privately created and were not expected to have public write-ups, exact matches in the private setting are more likely to come from common penetration-testing commands rather than memorised machine-specific solutions. For example, basic enumeration commands such as `sudo -l`, or standard privilege-escalation checks may naturally appear across many machines. Happe et al. [18] in their study also found that the LLMs often generate repeated basic enumeration commands. Therefore, exact command matching provides stronger evidence of memorisation when it occurs on public VulnHub machines and aligns with machine-specific write-ups, but it is weaker evidence when the matched command is a generic command commonly used in penetration testing. For example in *easy3*, both GPT4o and Llama-3.1 were failed to generate exact wordlist for path enumeration, unlike in *Cengbox2* that GPT4o was able to suggest exact wordlist.

Moreover, detail result show that the private machines exhibited little to no improvement in exact command rate when using MemPentestGPT. Among the private machines, only *Easy1* showed an increase, from 0.0% with PentestGPT to 6.2% with MemPentestGPT. In contrast, *Easy3* and *Medium1* produced identical exact command rates across both tools, at 18.8% and 25.0%, respectively. Notably, *Medium2* showed a decrease when using MemPentestGPT, with the exact command rate declining from 23.1% to 15.4%. This suggests

that memory-triggering prompts did not substantially improve exact command reproduction on private machines. By contrast, the VulnHub machines generally showed higher exact command rates under MemPentestGPT. *Cengbox2*, *Library2*, and *Symfonos2* all improved when using MemPentestGPT, while *Sar* remained unchanged at 28.6%, as shown in Table 2.

Table 2. Machine Exact Command Rates

Source	Machine Name	PentestGPT	MemPentestGPT
Private	<i>Easy1</i>	0.0%	6.2%
	<i>Easy3</i>	18.8%	18.8%
	<i>Medium1</i>	25.0%	25.0%
	<i>Medium2</i>	23.1%	15.4%
VulnHub	<i>Cengbox: 2</i>	31.2%	43.8%
	<i>The Library: 2</i>	12.5%	18.8%
	<i>Sar</i>	28.6%	28.6%
	<i>Symfonos: 2</i>	22.2%	27.8%

The outcome composition in Figure 7 reinforces this interpretation. Across all configurations, successful tasks were divided into two categories: successes with exact command matches and successes without exact matches. On VulnHub, the green segments, representing "success with exact match", were generally larger than on private machines. For example, VulnHub MemPentestGPT GPT-4o had the largest success-with-exact-match proportion, while private-machine configurations showed smaller exact-match proportions. Nevertheless, Figure 7 also shows that a substantial share of successful tasks did not involve exact command matching. This means that memorisation was detectable, but it did not explain all successful outcomes. The tools also appeared to use general penetration-testing patterns, partial reasoning, or non-identical commands that still advanced the attack.

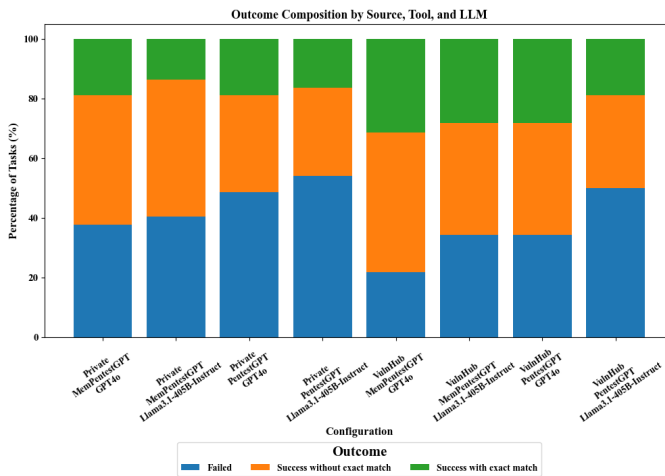


Fig. 7. Outcome Composition by Source, Tool, and Model

Overall, LLM-based penetration testing tools were moderately effective, particularly on public VulnHub machines. GPT-4o generally outperformed Llama-3.1-405B-Instruct, this is also in line

with Happe et al. [18] where OpenAI models perform better in command generation than Meta-Llama model that sometimes often hallucinate and gives unknown self generated command. Study from Nakano et al. [29] also mentioned that GPT-4 is performing better than other models in solving HTB machines. Furthermore, MemPentestGPT generally outperformed the baseline PentestGPT. The higher success rates, attempt success rates, and exact command rates on VulnHub suggest that public machines benefited from prior exposure to publicly available exploitation patterns. Ground-truth matching therefore reveals evidence of potential memorisation, especially for public machines with existing write-ups. However, memorisation was not the sole explanation for success, many successful tasks did not exactly match ground truth commands, and some exact matches on private machines were likely caused by generic suggestion commands, high-frequency penetration-testing commands. Thus, memorisation appears to be a measurable contributor to performance, but not the only mechanism driving tool effectiveness.

4.2 RQ2. Mutation-Based Analysis

In this section the study use MemPentestGPT because it was showing better result on previous section. Moreover, mutation-based test only tested on the successful task where both GPT-4o and Llama3.1-405B-Instruct had already succeeded under the original MemPentestGPT setting due to resource limitation. This section tests the adaptability of the tool when task information is constrained through masking or omission. Therefore, the results should be interpreted as an analysis of adaptability after baseline success, rather than as a general benchmark of penetration-testing capability. The details of the number of tasks tested is presented on Table 3

Table 3. Total Tasks by Source and Machine

Source	Machine Name	Total Task
VulnHub	<i>The Library: 2</i>	5
	<i>Sar</i>	7
	<i>Symfonos: 2</i>	6
	<i>Cengbox: 2</i>	10
Private	<i>Easy1</i>	3
	<i>Easy3</i>	4
	<i>Medium1</i>	7
	<i>Medium2</i>	6

As shown in Figure 8, mutation reduced the success rate for both models across private and VulnHub machines. In both sources, the Mask setting produced higher success rates than the Omit setting. This suggests that both models were more capable of continuing the task when partial information was still available, while full omission of key contextual details made adaptation more difficult. GPT-4o consistently achieved higher success rates than Llama3.1-405B-Instruct, indicating stronger robustness under mutated task conditions. However, Llama3.1-405B-Instruct also have higher performance in private machines with omitting key details rather than in VulnHub.

The attempt success rate result in Table 4 further shows that mutation affected efficiency. Attempt success rates were lower than

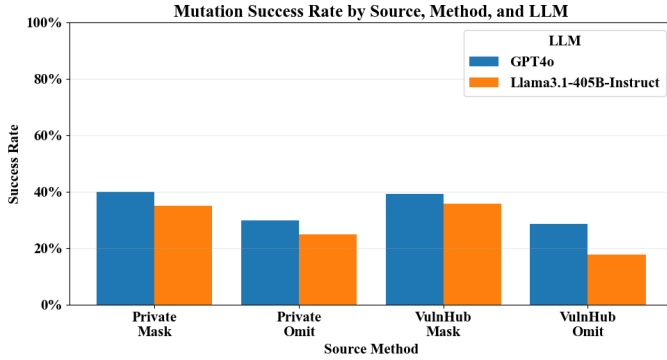


Fig. 8. Mutation based success rate

Table 4. Mutation-Based Attempt Success Rates by Source and Model

Source	Method	GPT-4o	Llama-3.1
Private	Mask	11.3% (8/71)	9.3% (7/75)
	Omit	7.7% (6/78)	6.3% (5/79)
VulnHub	Mask	11.5% (11/96)	9.3% (10/107)
	Omit	7.5% (8/106)	4.2% (5/119)

task-level success rates for both models, particularly under Omit. This means that even when the tool eventually succeeded, it often required multiple attempts. Therefore, the observed successes should not be interpreted as consistently reliable adaptation, but rather as partial adaptation under constrained conditions.

Table 5. Exact Command Rates under Mutation by Source and Model

Source	Method	GPT-4o	Llama-3.1
Private	Mask	5.0% (1/20)	0.0% (0/20)
	Omit	5.0% (1/20)	0.0% (0/20)
VulnHub	Mask	10.7% (3/28)	17.9% (5/28)
	Omit	7.1% (2/28)	3.6% (1/28)

The exact-command analysis in Table 5 shows that exact command reproduction under mutation was limited overall. In the private-machine setting, exact command matches were almost absent: GPT-4o produced only one exact command match under both Mask and Omit conditions, while Llama-3.1-405B-Instruct produced no exact command matches. VulnHub produced higher exact-command rates than private machines, particularly under the Mask condition, where Llama-3.1-405B-Instruct reached the highest rate at 17.9% (5/28), followed by GPT-4o at 10.7% (3/28). Since VulnHub machines are public and commonly accompanied by online write-ups, exact command reproduction in this setting is more consistent with potential memorisation. In the other hand, the Omit condition reduced the exact-command rate for both models on VulnHub, suggesting that removing key information weakened the models ability to reproduce commands exactly. The private machines were newly constructed and often relied on standard commands.

However, these results should be interpreted cautiously. In the private machines, the few exact command matches were largely

associated with basic penetration-testing commands, such as `sudo -l`, rather than machine-specific exploitation commands. Therefore, exact command matches in the private-machine setting do not necessarily provide strong evidence of memorisation. Instead, they may reflect the models use of common penetration-testing heuristics or standard privilege-escalation checks. By contrast, the higher exact-command rates on VulnHub, especially under the Mask condition, are more suggestive of potential memorisation because public machines are more likely to have existing write-ups and repeated solution patterns available online. For example, in the Sar machine, even after key details were masked, Llama-3.1-405B-Instruct generated a reverse-shell payload that closely resemble payloads reported in public write-ups, as shown below:

```
?plot=;python3 -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("<ATTACKER-IP>",<LISTENER-PORT>));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call(["/bin/bash","-i"]);'
```

This similarity provides stronger evidence of potential memorisation in the VulnHub setting [22, 31].

In Figure 9 the experiment shown task cross configurations, which most tasks fell into the Failed category, indicating that both models struggled when information was constrained. The proportion of Success without exact match was generally larger than Success with exact match, suggesting that most successful mutation cases were not simply reproduced commands. However, Success with exact match still appeared, especially in VulnHub configurations. This indicates that memorisation may have helped in some public-machine tasks, but it was not the dominant source of success across all mutated tasks.

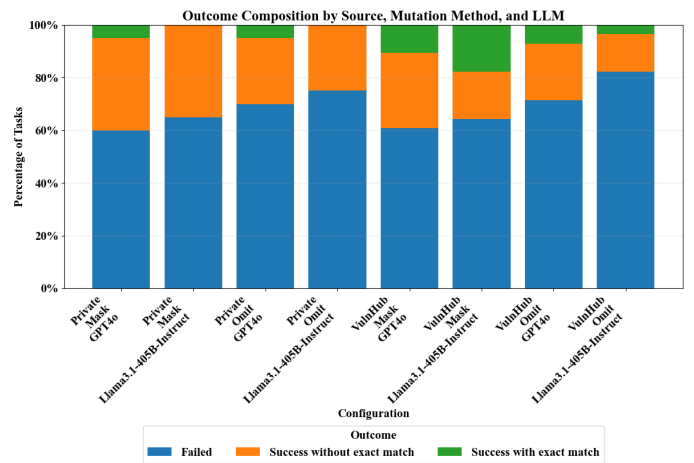


Fig. 9. Mutation Outcome Composition

The mutation-based results suggest that memorisation plays a limited and conditional role in MemPentestGPT. It can act as a strength when the mutated task still resembles a known public exploitation path, especially in VulnHub machines where public write-ups may exist. Therefore, MemPentestGPT shows partial adaptability under constrained information, but this adaptability is uneven. GPT-4o

adapted better than Llama3.1-405B-Instruct, and Mask was less disruptive than Omit. Memorisation appears to be a strength mainly in public-machine scenarios where prior write-ups may guide the model toward known commands. However, when exact matches involve generic commands in private machines, it should not be treated as strong memorisation evidence. In this study, memorisation is therefore best interpreted as a conditional strength in familiar public environments, but a weakness when the task requires deeper adaptation beyond common commands or recalled exploitation patterns.

5 Conclusion

6 Limitation

This study encountered several limitations that could affect the interpretation of the results.

- Each experimental condition was executed only once, without repeated trials. As LLM outputs can vary across runs, the absence of repetition limits the ability to measure output stability and statistical variation. Therefore, the results should be interpreted as indicative observations rather than definitive performance estimates.
- The experiments were conducted using PentestGPT version 0.14.0. As LLM-based penetration testing tools are actively developed, later versions may produce different results due to changes in prompting structure, tool integration, parsing behaviour, or task management.
- The testing process still required human intervention in PentestGPT 0.14.0. Although the LLM-based tools generated commands and suggested next steps, human judgement was needed to execute commands, interpret outputs, decide whether a task had progressed, and determine when no further useful suggestions were available. As a result, the evaluation reflects an assisted penetration testing.
- Responses differed across LLMs and tools even when they were tested on the same vulnerable machine. Because different models sometimes suggested different routes, commands, or task sequences, the experiment had to be adjusted based on the response produced in each case. This makes exact one-to-one comparison more difficult, as the tested commands were not always identical across models and tools.

Acknowledgments

To Indonesia Endowment Fund for Education (LPDP) for funding this research.

References

- [1] Helmi Mahditha Adam, Widyawan, and Guntur Dharma Putra. 2023. A Review of Penetration Testing Frameworks, Tools, and Application Areas. In *2023 IEEE 7th International Conference on Information Technology, Information Systems and Electrical Engineering (ICITISEE)*. 319–324. doi:10.1109/ICITISEE58992.2023.10404397
- [2] Ali Al-Kaswan, Maliheh Izadi, and Arie van Deursen. 2024. Traces of Memorisation in Large Language Models for Code. In *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering (Lisbon, Portugal) (ICSE '24)*. Association for Computing Machinery, New York, NY, USA, Article 78, 12 pages. doi:10.1145/3597503.3639133
- [3] Stella Biderman, USVSN Sai Prashanth, Lintang Sutawika, Hailey Schoelkopf, Quentin Anthony, Shivanshu Purohit, and Edward Raff. 2023. Emergent and predictable memorization in large language models. In *Proceedings of the 37th International Conference on Neural Information Processing Systems (NIPS '23)*. Curran Associates Inc., Red Hook, NY, USA. event-place: New Orleans, LA, USA.
- [4] Nicholas Carlini, Daphne Ippolito, Matthew Jagielski, Katherine Lee, Florian Tramèr, and Chiyuan Zhang. 2023. Quantifying Memorization Across Neural Language Models. arXiv:2202.07646 [cs.LG] <https://arxiv.org/abs/2202.07646>
- [5] Nicholas Carlini, Chang Liu, Áslfar Erlingsson, Jernej Kos, and Dawn Song. 2019. The secret sharer: evaluating and testing unintended memorization in neural networks. In *Proceedings of the 28th USENIX Conference on Security Symposium (SEC'19)*. USENIX Association, USA, 267–284. event-place: Santa Clara, CA, USA.
- [6] Nicholas Carlini, Florian Tramèr, Eric Wallace, Matthew Jagielski, Ariel Herbert-Voss, Katherine Lee, Adam Roberts, Tom Brown, Dawn Song, Áslfar Erlingsson, Alina Oprea, and Colin Raffel. 2021. Extracting Training Data from Large Language Models. In *30th USENIX Security Symposium (USENIX Security 21)*. USENIX Association, 2633–2650. <https://www.usenix.org/conference/usenixsecurity21/presentation/carlini-extracting>
- [7] Brian Challita and Pierre Parrend. 2025. RedTeamLLM: an Agentic AI framework for offensive security. doi:10.48550/arXiv.2505.06913 arXiv:2505.06913 [cs].
- [8] Wentao Chen, Lizhe Zhang, Li Zhong, Letian Peng, Zilong Wang, and Jingbo Shang. 2025. Memorize or Generalize? Evaluating LLM Code Generation with Evolved Questions. doi:10.48550/ARXIV.2503.02296 Version Number: 1.
- [9] CVE. [n. d.]. Common Vulnerabilities and Exposures. <https://www.cve.org/About/Overview>. [Accessed 29-08-2025].
- [10] Hanzheng Dai, Yuanliang Li, Jun Yan, and Zhibo Zhang. 2025. RefPentester: A Knowledge-Informed Self-Reflective Penetration Testing Framework Based on Large Language Models. doi:10.48550/arXiv.2505.07089 arXiv:2505.07089 [cs].
- [11] Gelei Deng, Yi Liu, Víctor Mayoral-Vilches, Peng Liu, Yuekang Li, Yuan Xu, Tianwei Zhang, Yang Liu, Martin Pinzger, and Stefan Rass. 2024. PENTESTGPT: evaluating and harnessing large language models for automated penetration testing. In *Proceedings of the 33rd USENIX Conference on Security Symposium (Philadelphia, PA, USA) (SEC '24)*. USENIX Association, USA, Article 48, 18 pages.
- [12] FriendlyAI Corp. 2026. FriendlyAI: The Frontier AI Inference Cloud. <https://friendly.ai/> Accessed: 2026-05-24.
- [13] Luca Gioacchini, Marco Mellia, Idilio Drago, Alexander Delsanto, Giuseppe Siracusano, and Roberto Bifulco. 2024. AutoPenBench: Benchmarking Generative Agents for Penetration Testing. doi:10.48550/arXiv.2410.03225 arXiv:2410.03225 [cs].
- [14] Dhruva Goyal, Sitaraman Subramanian, Aditya Peela, and Nisha P. Shetty. 2025. Hacking, The Lazy Way: LLM Augmented Pentesting. doi:10.48550/arXiv.2409.09493 arXiv:2409.09493 [cs].
- [15] HACKTHEBOX. [n. d.]. Hack The Box: The #1 Cybersecurity Performance Center — hackthebox.com. <https://www.hackthebox.com/>. [Accessed 27-08-2025].
- [16] Andreas Happe and Jürgen Cito. 2023. Getting pwned by AI: Penetration Testing with Large Language Models. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. ACM, San Francisco CA USA, 2082–2086. doi:10.1145/3611643.3613083
- [17] Andreas Happe and Jürgen Cito. 2025. On the Surprising Efficacy of LLMs for Penetration-Testing. doi:10.48550/arXiv.2507.00829 arXiv:2507.00829 [cs].
- [18] Andreas Happe, Aaron Kaplan, and Jürgen Cito. 2026. LLMs as Hackers: Autonomous Linux Privilege Escalation Attacks. *Empirical Software Engineering* 31, 3 (May 2026), 70. doi:10.1007/s10664-025-10758-3
- [19] Valentin Hartmann, Anshuman Suri, Vincent Bindschaedler, David Evans, Shruti Tople, and Robert West. 2023. SoK: Memorization in General-Purpose Large Language Models. doi:10.48550/ARXIV.2310.18362 Version Number: 1.
- [20] Eric Hilario, Sami Azam, Jawahar Sundaram, Khwaja Imran Mohammed, and Bharanidharan Shanmugam. 2024. Generative AI for pentesting: the good, the bad, the ugly. *International Journal of Information Security* 23, 3 (June 2024), 2075–2097. doi:10.1007/s10207-024-00835-x
- [21] Junjie Huang and Quanyan Zhu. 2023. PenHeal: A Two-Stage LLM Framework for Automated Pentesting and Optimal Remediation. In *Proceedings of the Workshop on Autonomous Cybersecurity*. ACM, Salt Lake City UT USA, 11–22. doi:10.1145/3689933.3690831
- [22] iihack. 2020. Vulnhub 425 SAR 1. Blog post. <https://www.iihack.com/2020/02/15/vulnhub-425.html> Accessed: 2026-05-24.
- [23] Isamu Isozaki, Manil Shrestha, Rick Console, and Edward Kim. 2025. Towards Automated Penetration Testing: Introducing LLM Benchmark, Analysis, and Improvements. In *Adjunct Proceedings of the 33rd ACM Conference on User Modeling, Adaptation and Personalization*. ACM, New York City USA, 404–419. doi:10.1145/3708319.3733804
- [24] René Just, Darioh Jalali, and Michael D. Ernst. 2014. Defects4J: a database of existing faults to enable controlled testing studies for Java programs. In *Proceedings of the 2014 International Symposium on Software Testing and Analysis*. ACM, San Jose CA USA, 437–440. doi:10.1145/2610384.2628055
- [25] He Kong, Die Hu, Jingguo Ge, Liangxiong Li, Tong Li, and Bingzhen Wu. 2025. VulnBot: Autonomous Penetration Testing for A Multi-Agent Collaborative Framework. doi:10.48550/arXiv.2501.13411 arXiv:2501.13411 [cs].

- [26] Jiaolong Kong, Xiaofei Xie, and Shangqing Liu. 2025. Demystifying Memorization in LLM-Based Program Repair via a General Hypothesis Testing Framework. *Proceedings of the ACM on Software Engineering* 2, FSE (June 2025), 2712–2734. doi:10.1145/3729390
- [27] Yaniv Leviathan, Matan Kalman, and Yossi Matias. 2025. Prompt Repetition Improves Non-Reasoning LLMs. arXiv:2512.14982 [cs.LG] <https://arxiv.org/abs/2512.14982>
- [28] Johnny Long, Bill Gardner, and Justin Brown. 2016. *Google Hacking for Penetration Testers*. Elsevier. doi:10.1016/C2013-0-14283-3
- [29] Katsuaki Nakano, Reza Fayyazi, Shanchieh Jay Yang, and Michael Zuzak. 2025. Guided Reasoning in LLM-Driven Penetration Testing Using Structured Attack Trees. doi:10.48550/arXiv.2509.07939 arXiv:2509.07939 [cs.CR].
- [30] Milad Nasr, Nicholas Carlini, Jonathan Hayase, Matthew Jagielski, A. Feder Cooper, Daphne Ippolito, Christopher A. Choquette-Choo, Eric Wallace, Florian Tramèr, and Katherine Lee. 2023. Scalable Extraction of Training Data from (Production) Language Models. doi:10.48550/arXiv.2311.17035 arXiv:2311.17035 [cs].
- [31] Bhanuprathap Reddy. 2024. Machines I Solved for OSCP (SAR). Medium. <https://avahack.medium.com/machines-i-solved-for-osp-sar-69e8a4c1b5e9> Accessed: 2026-05-24.
- [32] VulnHub. [n. d.]. Vulhub - Open-Source Vulnerable Docker Environments — vulhub.org. <https://vulnhub.org/>. [Accessed 09-09-2025].
- [33] VulnHub. [n. d.]. Difficulty ~ VulnHub. <https://www.vulnhub.com/difficulty/>. Accessed: 2026-05-15.
- [34] VulnHub. [n. d.]. Vulnerable By Design VulnHub — vulnhub.com. <https://www.vulnhub.com/>. [Accessed 27-08-2025].
- [35] Jiachen Xu, Jack W. Stokes, Geoff McDonald, Xuesong Bai, David Marshall, Siyue Wang, Adith Swaminathan, and Zhou Li. 2024. AutoAttacker: A Large Language Model Guided System to Implement Automatic Cyber-attacks. doi:10.48550/arXiv.2403.01038 arXiv:2403.01038 [cs].
- [36] Yuxuan Zhu, Antony Kellermann, Akul Gupta, Philip Li, Richard Fang, Rohan Bindu, and Daniel Kang. 2025. Teams of LLM Agents can Exploit Zero-Day Vulnerabilities. doi:10.48550/arXiv.2406.01637 arXiv:2406.01637 [cs].